

Scanning an Active Directory Domain Controller for Vulnerabilities (3e)

Access Control and Identity Management, Third Edition - Lab 08

Student:

Christopher Phan

Email:

cphan@udallas.edu

Time on Task:

11 hours, 15 minutes

Progress:

78%

Report Generated: Tuesday, July 5, 2022 at 9:05 PM

Section 1: Hands-On Demonstration

Part 1: Conduct a Port Scan

5. Make a screen capture showing the **nmap** scan results for the targeted port scan of the 172.30.0.0/24 subnet.

```
Administrator: Command Prompt  Scanning an Active Directory Domain Controller for Vulnerabilities (3e)
ThNmap scan report for 172.30.0.15
Host is up (0.00s latency).
PORT      STATE SERVICE
80/tcp    closed http
MAC Address: 00:50:56:AB:35:A9 (VMware)

Net
Nmap scan report for 172.30.0.16
Host is up (0.00s latency).
PORT      STATE SERVICE
80/tcp    open  http
MAC Address: 00:50:56:AB:98:7A (VMware)

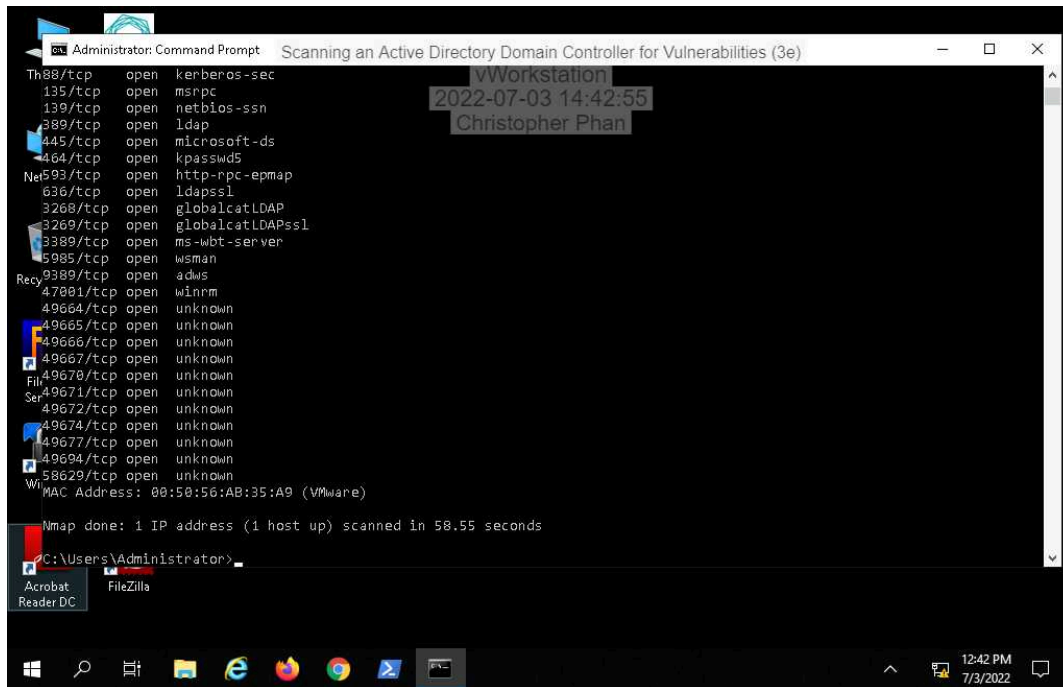
Recy
Nmap scan report for 172.30.0.18
Host is up (0.00s latency).
PORT      STATE SERVICE
80/tcp    open  http
MAC Address: 00:50:56:AB:83:45 (VMware)

Fil
Ser
Nmap scan report for 172.30.0.2
Host is up (0.00s latency).
PORT      STATE SERVICE
80/tcp    open  http

Wi
Nmap done: 256 IP addresses (4 hosts up) scanned in 7.45 seconds

C:\Users\Administrator>
```

7. **Make a screen capture** showing the **nmap** scan results of the full port scan of **TargetWindows01**.



8. **Compare** the results of the default scan with the results of the full port scan. What are the differences between the two reports?

For the default scan, Nmap only scans only the most common 1,000 TCP and UDP ports that are valid. For the full scan, it scans all 65,535 ports within the network and determining which ones are valid ports. The amount of ports shown for a default scan is 13 ports, while for a full port scan, there are 27 ports.

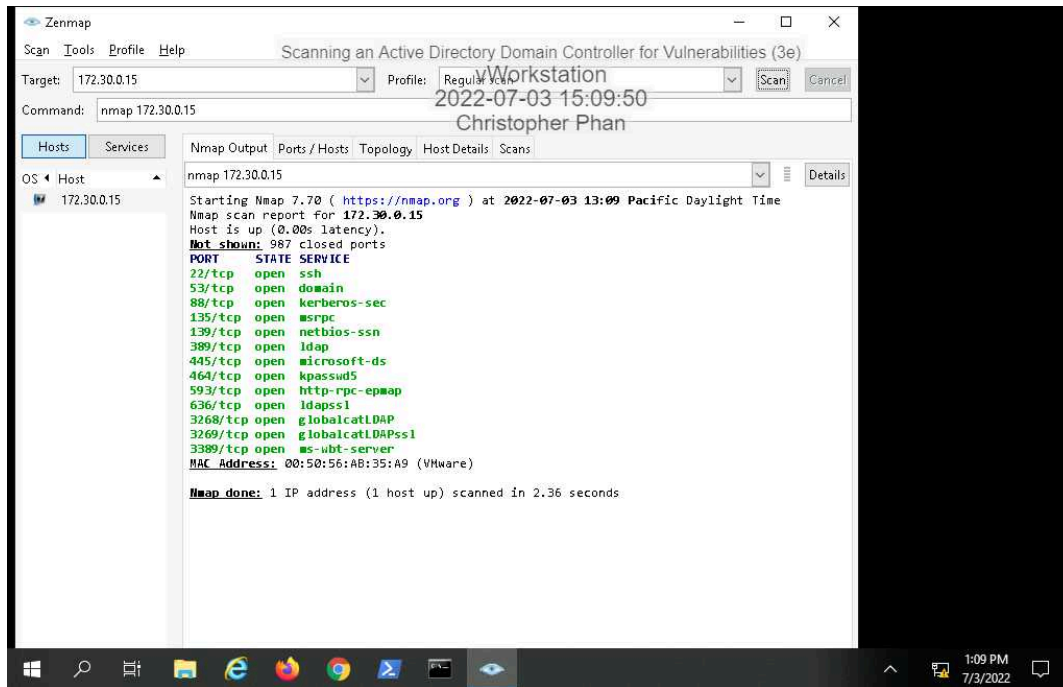
9. **Provide** one reason that you might perform an abbreviated scan.

One reason to do a default port scan is that it is extremely quicker to do this type of scan with immediate results, and also it shows the most commonly used 1,000 ports.

10. **Provide** one reason that you might perform a full scan.

One reason to do a full scan is that it scans the entirety of all ports which are valid and goes beyond than the default common 1,000 ports.

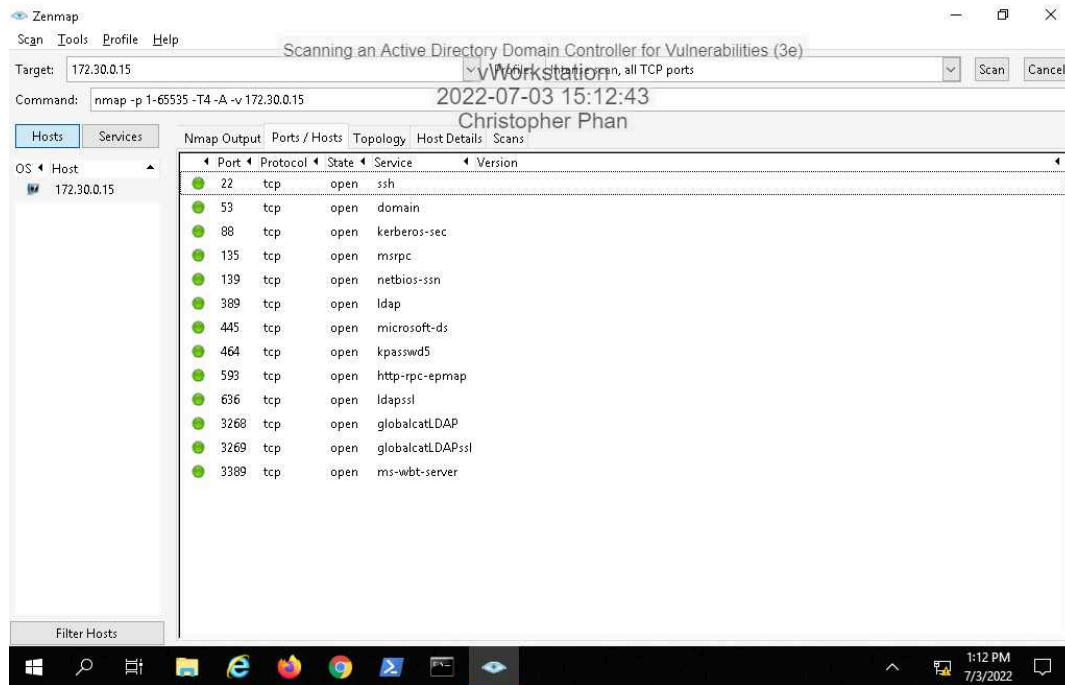
16. Make a screen capture showing the Zenmap scan results for the regular scan of TargetWindows01.



Scanning an Active Directory Domain Controller for Vulnerabilities (3e)

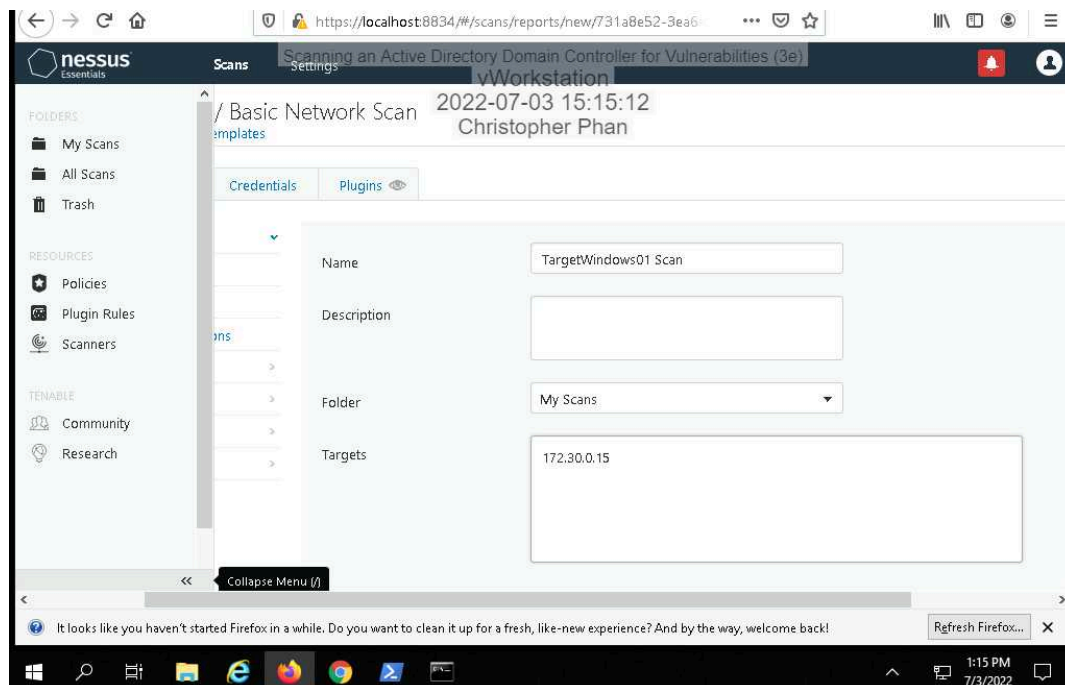
Access Control and Identity Management, Third Edition - Lab 08

20. Make a screen capture showing the Zenmap scan results for the intense scan of all TCP ports on TargetWindows01.

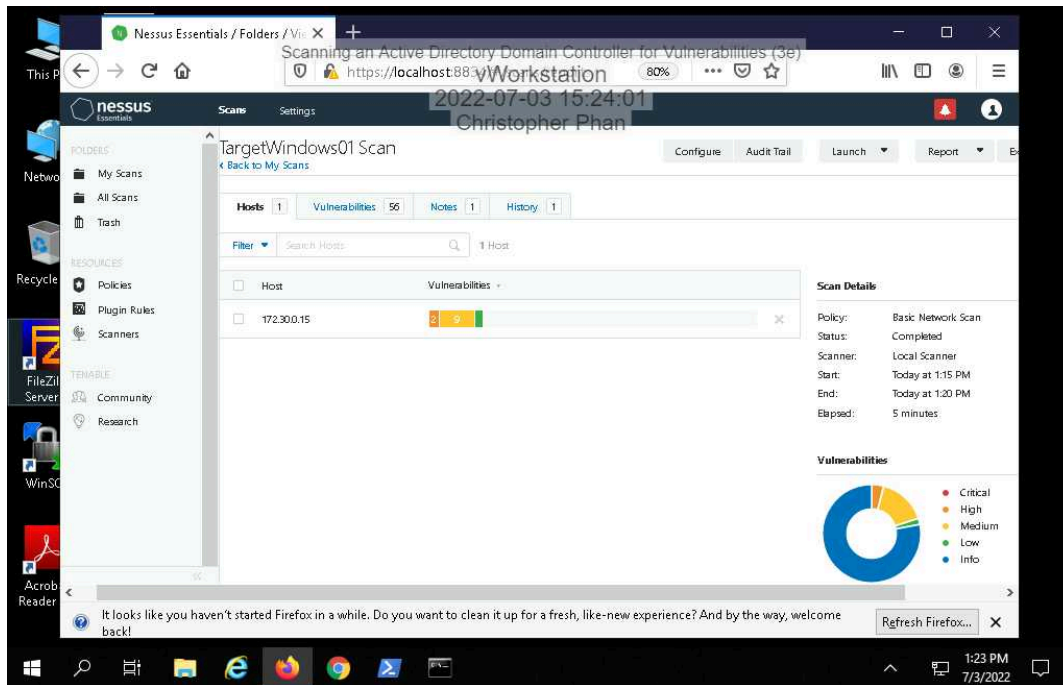


Part 2: Conduct a Network Vulnerability Scan

7. Make a screen capture showing the TargetWindows01 Scan configuration.



11. Make a screen capture showing the TargetWindows01 Scan results.



Part 3: Interpret the Results of a Network Vulnerability Scan

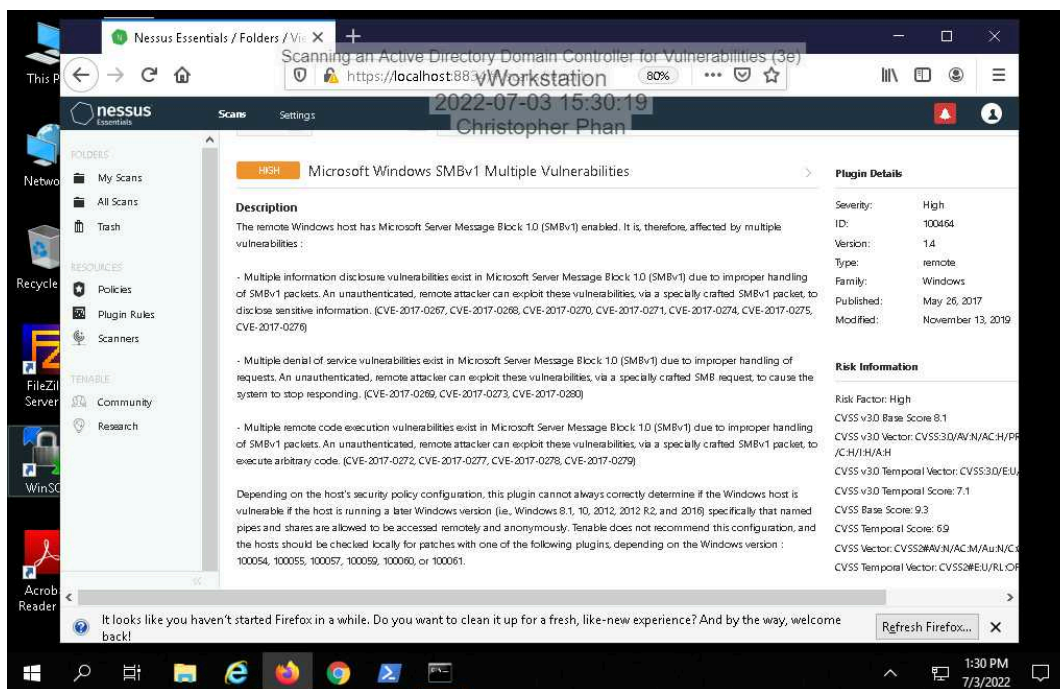
2. **Record** the number of Critical, High, Medium, and Low vulnerabilities in the initial scan of TargetWindows01.

There are 0 Critical Vulnerabilities, 2 High Vulnerabilities, 9 Medium Vulnerabilities, and 1 Low Vulnerability.

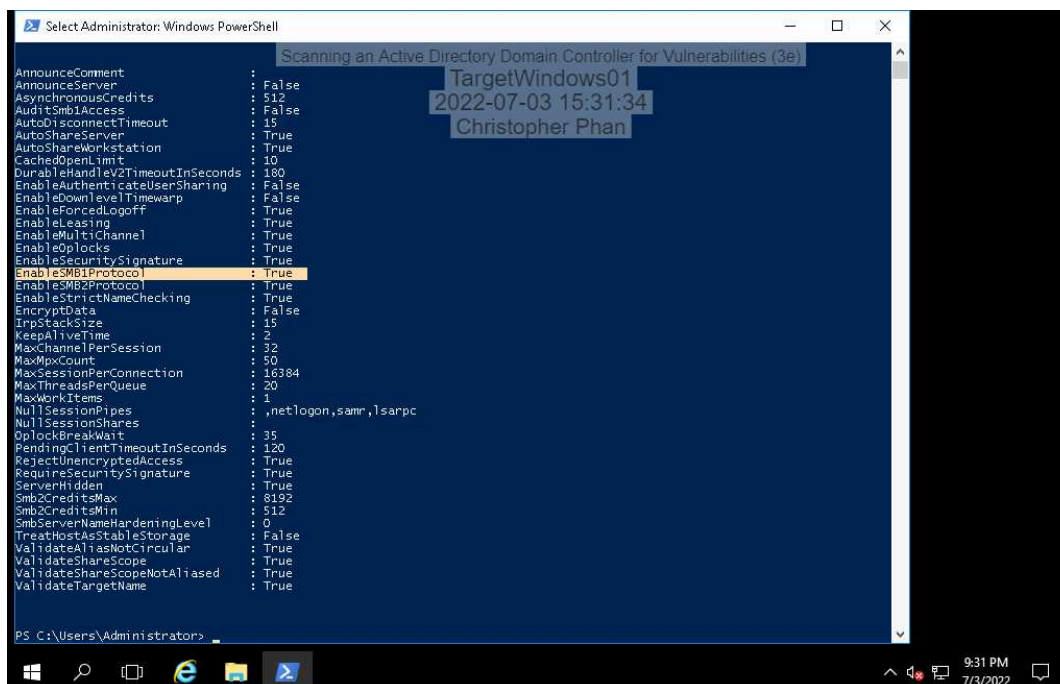
5. **Describe** one method that you could use to correct the vulnerability.

One method that can be done to resolve this vulnerability by updating the Windows Server 2016: KB4019472, as this workstation's OS system being Windows Server.

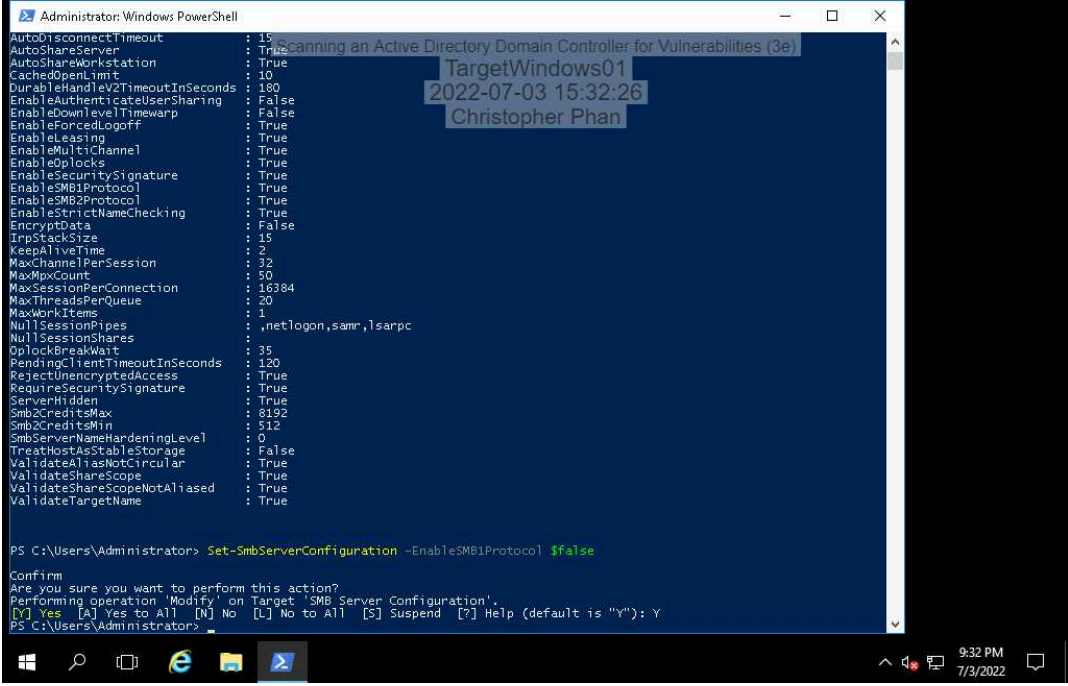
6. Make a screen capture showing the detailed Microsoft SMBv1 Multiple Vulnerabilities report.



11. Make a screen capture showing the EnableSMB1Protocol status.



14. Make a screen capture showing the executed **Set-SmbServerConfiguration** cmdlet.



```
Administrator: Windows PowerShell
AutoDisconnectTimeout : 15
AutoShareServer : True
AutoShareWorkstation : True
CachedOpenLimit : 10
DurableHandleV2TimeoutInSeconds : 180
EnableAuthenticatedUsersSharing : False
EnableDownlevelTimewarp : False
EnableForcedLogoff : True
EnableLeasing : True
EnableMultiChannel : True
EnableOplocks : True
EnableSecuritySignature : True
EnableSMB1Protocol : True
EnableSMB2Protocol : True
EnableStrictNameChecking : True
EncryptData : False
IpStackSize : 15
KeepAliveTime : 2
MaxChannelPerSession : 32
MaxMaxCount : 50
MaxSessionPerConnection : 16384
MaxThreadsPerQueue : 20
MaxWorkItems : 1
NullSessionPipes : ,netlogon,samr,lsarpc
NullSessionShares :
OplockBreakWait : 35
PendingClientTimeoutInSeconds : 120
RejectUnencryptedAccess : True
RequireSecuritySignature : True
ServerHidden : True
Smb2CreditsMax : 8192
Smb2CreditsMin : 512
SmbServerNameHardeningLevel : 0
TreatHostAsStableStorage : False
ValidateAliasNotCircular : True
ValidateShareScope : True
ValidateShareScopeNotAliased : True
ValidateTargetName : True

PS C:\Users\Administrator> Set-SmbServerConfiguration -EnableSMB1Protocol $false

Confirm
Are you sure you want to perform this action?
Performing operation 'Modify' on Target 'SMB Server Configuration'.
[Y] Yes [A] Yes to All [N] No [L] No to All [S] Suspend [?] Help (default is "Y"): Y
PS C:\Users\Administrator>
```

21. **Record** the number of Critical, High, Medium, and Low vulnerabilities in the second scan of TargetWindows01.

There are 0 Critical and High Vulnerabilities, 9 Medium Vulnerabilities, and 1 Low Vulnerability.

Scanning an Active Directory Domain Controller for Vulnerabilities (3e)

Access Control and Identity Management, Third Edition - Lab 08

22. Make a screen capture showing the updated TargetWindows01 vulnerability list.

The screenshot shows the Nessus Essentials web interface. The main content area displays the results for a scan named 'TargetWindows01 Scan'. The interface includes a sidebar with navigation options like 'My Scans', 'All Scans', 'Trash', 'Policies', 'Plugin Rules', 'Scanners', 'Community', and 'Research'. The main area has tabs for 'Hosts', 'Vulnerabilities', 'Notes', and 'History'. The 'Vulnerabilities' tab is active, showing a list of 55 vulnerabilities. The table below lists several vulnerabilities:

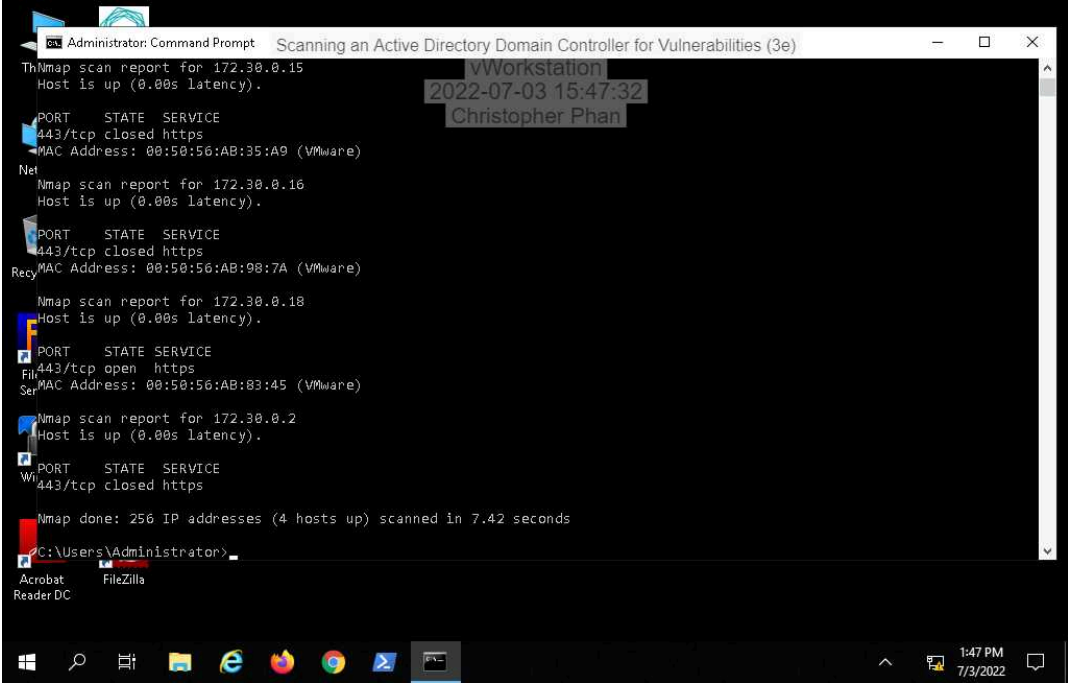
Sev	Name	Family	Count
MEDIUM	Microsoft Windows Re...	Windows	1
MEDIUM	SSL Certificate Cannot B...	General	1
MEDIUM	SSL Certificate with Who...	General	1
MEDIUM	SSL Medium Strength C...	General	1
MEDIUM	SSL RC4 Cipher Suites S...	General	1
MEDIUM	SSL Self-Signed Certificate	General	1
MEDIUM	Terminal Services Doesn...	Misc.	1

On the right side, there is a 'Scan Details' section with information about the policy, status, scanner, start/end times, and elapsed time. Below this is a 'Vulnerabilities' section with a donut chart showing the distribution of severity levels: Critical (red), High (orange), Medium (yellow), Low (green), and Info (blue).

Section 2: Applied Learning

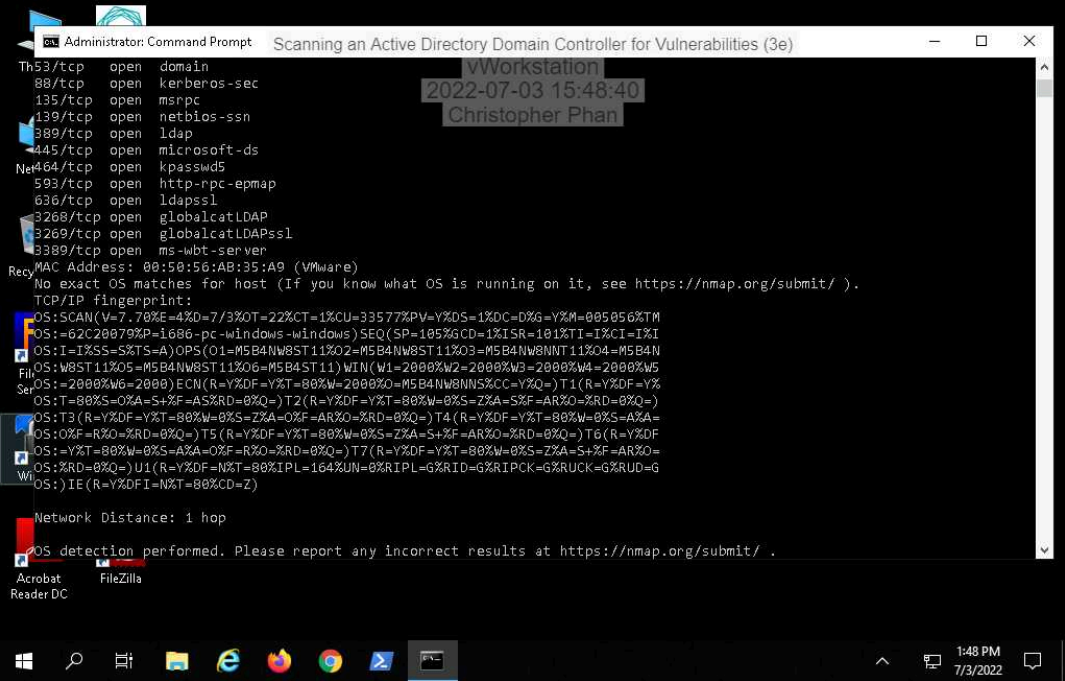
Part 1: Conduct a Port Scan

5. Make a screen capture showing the nmap scan results for the targeted port scan of the 172.30.0.0-20 IP address range.



```
Administrator: Command Prompt  Scanning an Active Directory Domain Controller for Vulnerabilities (3e)
ThNmap scan report for 172.30.0.15
Host is up (0.00s latency).
PORT      STATE SERVICE
443/tcp   closed https
MAC Address: 00:50:56:AB:35:A9 (VMware)
Net
Nmap scan report for 172.30.0.16
Host is up (0.00s latency).
PORT      STATE SERVICE
443/tcp   closed https
MAC Address: 00:50:56:AB:98:7A (VMware)
Recy
Nmap scan report for 172.30.0.18
Host is up (0.00s latency).
PORT      STATE SERVICE
443/tcp   open  https
MAC Address: 00:50:56:AB:83:45 (VMware)
File
Ser
Nmap scan report for 172.30.0.2
Host is up (0.00s latency).
PORT      STATE SERVICE
443/tcp   closed https
Wi
Nmap done: 256 IP addresses (4 hosts up) scanned in 7.42 seconds
C:\Users\Administrator>
```

7. Make a screen capture showing the nmap scan results of the Operating System detection scan.

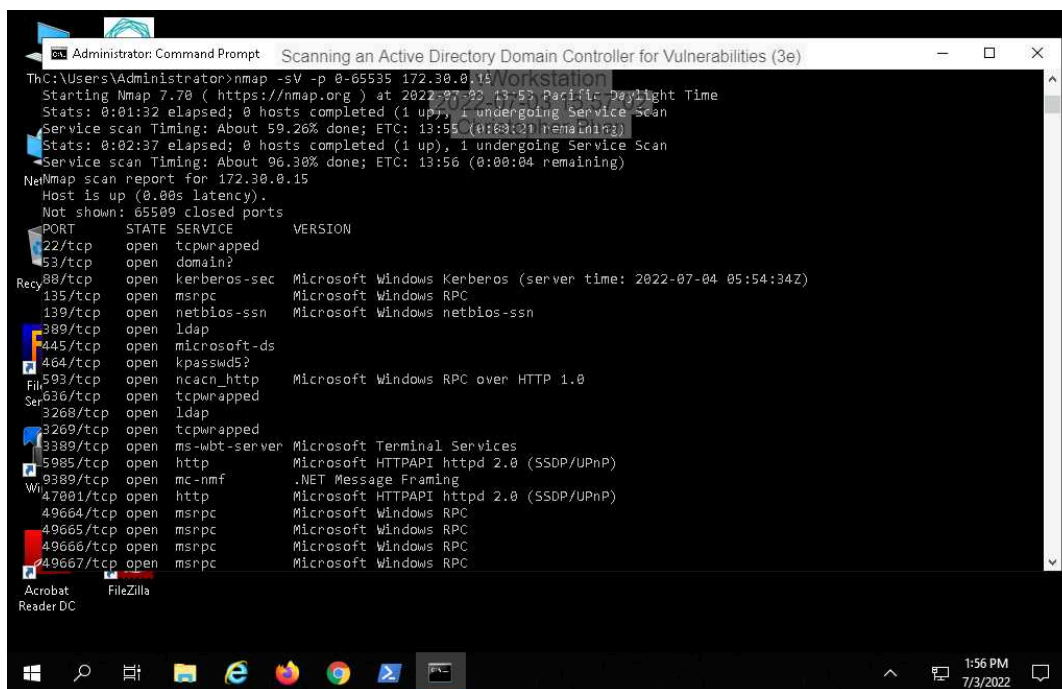


```
Administrator: Command Prompt  Scanning an Active Directory Domain Controller for Vulnerabilities (3e)
Th53/tcp open  domain
88/tcp open  kerberos-sec
135/tcp open  msrpc
139/tcp open  netbios-ssn
389/tcp open  ldap
445/tcp open  microsoft-ds
Net464/tcp open  kpasswd5
593/tcp open  http-rpc-epmap
636/tcp open  ldapssl
3268/tcp open  globalcatLDAP
3269/tcp open  globalcatLDAPssl
3389/tcp open  ms-wbt-server
Rece MAC Address: 00:50:56:AB:35:A9 (VMware)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.70%E=4%D=7/3%OT=22%CT=1%CU=33577%PV=Y%DS=1%DC=D%G=Y%M=005056%TM
OS:=62C20079P=i686-pc-windows-windows)SEQ(SP=105%GCD=1%ISR=101%TI=I%CI=I%I
OS:I=I%SS=5%TS=A)OPS(O1=M5B4NW8ST11%O2=M5B4NW8ST11%O3=M5B4NW8NNT11%O4=M5B4N
OS:W8ST11%O5=M5B4NW8ST11%O6=M5B4ST11)WIN(W1=2000%W2=2000%W3=2000%W4=2000%W5
OS:=2000%W6=2000)ECN(R=Y%DF=Y%T=80%W=2000%O=M5B4NW8NNS%CC=Y%Q=)T1(R=Y%DF=Y%
OS:T=80%S=O%A=S+F=AS%RD=0%Q=)T2(R=Y%DF=Y%T=80%W=0%S=Z%A=S%F=AR%O=%RD=0%Q=)
OS:T3(R=Y%DF=Y%T=80%W=0%S=Z%A=O%F=AR%O=%RD=0%Q=)T4(R=Y%DF=Y%T=80%W=0%S=Z%A=
OS:O%F=AR%O=%RD=0%Q=)T5(R=Y%DF=Y%T=80%W=0%S=Z%A=S+F=AR%O=%RD=0%Q=)T6(R=Y%DF
OS:=Y%T=80%W=0%S=Z%A=O%F=AR%O=%RD=0%Q=)T7(R=Y%DF=Y%T=80%W=0%S=Z%A=S+F=AR%O=
OS:%RD=0%Q=)U1(R=Y%DF=N%T=80%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G
OS:)%IE(R=Y%DFI=N%T=80%CD=Z)
Network Distance: 1 hop
OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Acrobat Reader DC  FileZilla
```

8. Identify the Operating System identified for TargetWindows01.

Microsoft Window Servers 2019 Standard

10. Make a screen capture showing the nmap scan results of the Service Version detection scan.



```
Administrator: Command Prompt
Scanning an Active Directory Domain Controller for Vulnerabilities (3e)

ThC:\Users\Administrator>nmap -sV -p 0-65535 172.30.0.15
Starting Nmap 7.70 ( https://nmap.org ) at 2022-07-03 13:53 Pacific Daylight Time
Stats: 0:01:32 elapsed; 0 hosts completed (1 up); 1 undergoing Service Scan
Service scan Timing: About 59.26% done; ETC: 13:55 (0:03:21 remaining)
Stats: 0:02:37 elapsed; 0 hosts completed (1 up); 1 undergoing Service Scan
Service scan Timing: About 96.30% done; ETC: 13:56 (0:00:04 remaining)
Nmap scan report for 172.30.0.15
Host is up (0.00s latency).
Not shown: 65509 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  tcpwrapped
53/tcp    open  domain?
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2022-07-04 05:54:34Z)
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp   open  ldap         Microsoft Windows LDAP
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd?
593/tcp   open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap         Microsoft Windows LDAP
3269/tcp  open  tcpwrapped
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
5985/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
5989/tcp  open  mc-nmf       .NET Message Framing
7001/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
49664/tcp open  msrpc        Microsoft Windows RPC
49665/tcp open  msrpc        Microsoft Windows RPC
49666/tcp open  msrpc        Microsoft Windows RPC
49667/tcp open  msrpc        Microsoft Windows RPC
```

11. Identify the service and version running on TCP port 5985.

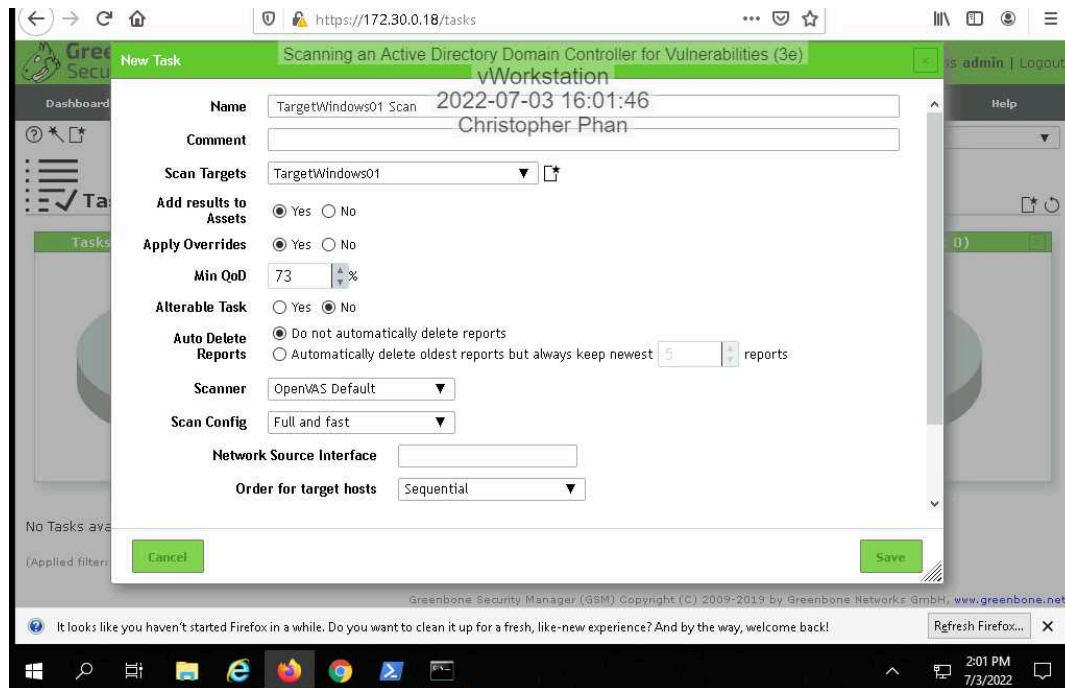
It is a "HTTP" service, and the version of it running is "Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)."

Part 2: Conduct a Network Vulnerability Scan with OpenVAS

Scanning an Active Directory Domain Controller for Vulnerabilities (3e)

Access Control and Identity Management, Third Edition - Lab 08

7. Make a screen capture showing the new OpenVAS task.



11. Make a screen capture showing the OpenVAS scan report.



Part 3: Interpret an OpenVAS Report

4. **Describe** one method that you could use to correct the vulnerability.

What Greenbone suggests to do as a solution is to go through a "vendorfix", where for the vulnerability to be fixed is to look through released updates from the vendor.

5. **Make a screen capture** showing the **detailed OpenVAS vulnerability report**.

The screenshot displays the Greenbone Security Manager (GSM) web interface. The top navigation bar includes links for Dashboards, Scans, Assets, SecInfo, Configuration, Extras, Administration, and Help. The main content area shows a detailed report for the vulnerability 'Microsoft Windows SMB Server Multiple Vulnerabilities-Remote (4013389)'. The report includes a Summary, Detection Result, Insight, Detection Method, and Affected Software/OS.

Summary
This host is missing a critical security update according to Microsoft Bulletin MS17-010.

Detection Result
Vulnerability was detected according to the Detection Method.

Insight
Multiple flaws exist due to the way that the Microsoft Server Message Block 1.0 (SMBv1) server handles certain requests.

Detection Method
Send the crafted SMB transaction request with fid = 0 and check the response to confirm the vulnerability.
Details: [Microsoft Windows SMB Server Multiple Vulnerabilities-Remote \(4013389\)...](#)OID: 1.3.6.1.4.1.25623.1.0.810676
Version used: 2019-05-03T10:54:50Z

Affected Software/OS
Microsoft Windows 10 x22/x64 Edition

The interface also shows a table with columns for ID, Severity, Score, and Hosts. The current entry has a severity of 9.3 (High), a score of 95 %, and is located at 172.30.0.15. The interface is logged in as 'admin' and shows the date 2022-07-03 16:15:11.

Scanning an Active Directory Domain Controller for Vulnerabilities (3e)

Access Control and Identity Management, Third Edition - Lab 08

11. Make a screen capture showing the **OpenVAS** scan report without the SMBv1-related vulnerabilities.

Greenbone Security Manager

Scanning an Active Directory Domain Controller for Vulnerabilities (3e)

2022-07-03 16:24:27

Logged in as admin | Logout

Christopher Phan

Filter

Sun, Jul 3, 2022 9:16 PM UTC

Done

ID: 2cce7c43-8502-4eb8-8d1d-ce59251ec0e8

Created: 2022 9:16 PM UTC

Modified: 2022 9:24 PM UTC

Owner: admin

Information Results (34 of 35) Hosts (1 of 1) Ports (12 of 12) Applications (0 of 0) Operating Systems (1 of 1) CVEs (3 of 3) Closed CVEs (8 of 8) TLS Certificates (0 of 0) Error Messages (0 of 0) User Tags (0)

Vulnerability

Vulnerability	Severity	QoD	Host IP	Name	Location	Created
Check open ports	0.0 (Log)	95 %	172.30.0.15		3269/tcp	Sun, Jul 3, 2022 9:23 PM UTC
CPE Inventory	0.0 (Log)	80 %	172.30.0.15		general/CPE-T	Sun, Jul 3, 2022 9:23 PM UTC
Hostname Determination Reporting	0.0 (Log)	80 %	172.30.0.15		general/tcp	Sun, Jul 3, 2022 9:23 PM UTC

Greenbone Security Manager (GSM) Copyright (C) 2009-2019 by Greenbone Networks GmbH, www.greenbone.net

It looks like you haven't started Firefox in a while. Do you want to clean it up for a fresh, like-new experience? And by the way, welcome back!

Refresh Firefox...

Section 3: Challenge and Analysis

Part 1: Conduct a Vulnerability Scan

Make a screen capture showing the scan results overview, with the vulnerabilities identified by the scan.

Incomplete

Part 2: Interpret the Vulnerability Scan

Describe the vulnerability and its potential impact, including an example of how the vulnerability might be exploited.

Incomplete

Make a screen capture showing the detailed vulnerability report for the vulnerability you selected.

Incomplete

Report whether the vulnerability is valid or is a false positive and **describe** how you came to that conclusion.

Incomplete

Part 3: Analyze the CVSS Score

Identify the CVSS score and CVSS string for the vulnerability you selected in Part 2.

Incomplete

- What is the overall CVSS severity rating for the vulnerability you chose? Provide both the numeric score and the qualitative rating.

Incomplete

- The Privileges Required (PR) metric in a CVSS string describes the level of access that an attacker must have to exploit the vulnerability. What level of access is required for the vulnerability you identified?

Incomplete